

AdaCap-IIoT: A reference architecture for adaptive blockchain-enabled CapBAC[☆]

Argiro Anagnostopoulou^a , Dimitris Gritzalis^a *, Ioannis Mavridis^b

^a Department of Informatics, Athens University of Economics and Business, 76, Patission Str., Athens, GR-10434, Greece

^b Department of Applied Informatics, University of Macedonia, 156, Egnatia Str., Thessaloniki, GR-54636, Greece

ARTICLE INFO

Keywords:

Information flow control
Capability-based access control
Blockchain
Adaptive authorization
Industrial Internet of Things

ABSTRACT

Industrial Internet of Things (IIoT) environments require access-control mechanisms that can operate across heterogeneous, resource-constrained, latency-sensitive, and cross-domain infrastructures. Capability-Based Access Control (CapBAC) supports decentralized and fine-grained authorization, while blockchain can provide distributed trust, tamper-evident records, smart-contract automation, and auditability. However, existing blockchain-enabled CapBAC models often remain access-centric and provide limited support for complete capability lifecycle management, runtime adaptivity, privacy-preserving verification, robust revocation, controlled delegation, and post-authorization information flow monitoring. This work extends our comparative analysis of blockchain-enabled CapBAC for IIoT by examining baseline suitability, capability lifecycle coverage, runtime adaptivity, privacy protection, revocation and delegation robustness, and threat coverage. Based on the identified gaps, we propose AdaCap-IIoT, a reference architecture for adaptive blockchain-enabled CapBAC in IIoT environments. AdaCap-IIoT introduces a lifecycle-driven authorization workflow by separating ledger-based trust anchoring from edge-side authorization and enforcement. It combines zero-knowledge-based capability verification, modular smart-contract responsibilities, dynamic risk evaluation, adaptive revocation, and information flow monitoring. The architecture handles capabilities as dynamic authorization objects whose scope, duration, verification requirements, and renewal can adapt according to context, operational risk, and observed information flows. AdaCap-IIoT provides a structured foundation for privacy-aware, auditable, and lifecycle-driven access control in next-generation IIoT systems.

1. Introduction

Industrial Internet of Things (IIoT) interconnects sensors, actuators, controllers, gateways, edge services, and cloud platforms, forming highly distributed industrial ecosystems. This connectivity enables industrial infrastructures to support real-time monitoring, process automation, remote diagnostics, and data-driven decision-making. However, the same connectivity also increases the attack surface of industrial environments. Devices and services that were previously isolated now exchange operational data across heterogeneous networks. Consequently, threats such as unauthorized access, compromised devices, malicious insiders, token misuse, or uncontrolled information propagation can compromise the confidentiality, integrity, and availability of transmitted information.

Access control is a fundamental security requirement in IIoT systems. Although traditional models, such as Role-Based Access Control (RBAC) and Attribute-Based Access Control (ABAC), provide well-established frameworks for permission management, they often remain

limited in highly dynamic and decentralized industrial environments. IIoT systems involve resource-constrained devices, latency-sensitive operations, cross-domain interactions, as well as continuously changing operational conditions. In such environments, centralized authorization mechanisms may introduce bottlenecks and single points of failure, whereas static authorization rules often fail to adapt to changes in device behavior, context, or operational risk.

Capability-Based Access Control (CapBAC) has emerged as a promising alternative for distributed IoT and IIoT environments. In CapBAC, capability tokens contain the access rights that specify which subject may perform which operation on which object. This model naturally supports fine-grained authorization, delegation, and decentralized permission management. However, conventional CapBAC approaches still present several challenges. They must securely manage capability issuance, verification, delegation, revocation, and auditability, while they should ensure that stolen or misused capabilities can be invalidated efficiently. Moreover, a valid capability does not necessarily

[☆] This article is part of a Special issue entitled: 'SECRYPT 2025' published in Computers & Security.

* Corresponding author.

E-mail addresses: anagnostopoulou@aub.gr (A. Anagnostopoulou), dgrit@aub.gr (D. Gritzalis), mavridis@uom.edu.gr (I. Mavridis).

prevent post-authorization misuse. A compromised subject may still propagate data to unauthorized devices, services, or domains.

Blockchain technology can enhance CapBAC by supporting decentralized trust, tamper-evident records, smart-contract-based automation, and auditable management of capability-related events. Blockchain-enabled CapBAC models can reduce reliance on centralized authorities and improve transparency across capability issuance, delegation, revocation, and verification, making blockchain well suited to supporting access control in distributed IIoT environments. However, blockchain integration does not address all access-control challenges in IIoT environments. Ledger transparency may reveal critical operational metadata, on-chain verification may increase latency, and smart-contract logic may limit flexibility, updatability, and scalability.

In our previous work, we systematically compared blockchain-enabled CapBAC models for IIoT across twelve criteria, including scalability, performance, decentralization, smart-contract adoption, security, and privacy protection (Anagnostopoulou et al., 2025). The analysis showed that this direction is promising for IIoT access control, but also revealed limitations in privacy protection, low-latency operation, throughput, decentralization, and adaptive authorization. These findings motivate the synthesis of existing strengths into a coherent adaptive architecture.

To address these limitations, we propose AdaCap-IIoT, a reference architecture for adaptive blockchain-enabled Capability-Based Access Control in IIoT environments. AdaCap-IIoT combines five complementary design principles: (i) privacy-preserving capability verification, (ii) edge-based authorization, (iii) dynamic risk evaluation, (iv) adaptive revocation, and (v) information flow-aware monitoring. The architecture separates trust anchoring from operational enforcement. The ledger records key identity, policy, capability, delegation, revocation, and audit commitments, while edge nodes perform privacy-preserving verification, and adaptive enforcement near the industrial process. This preserves auditability without placing every access request on-chain or exposing unnecessary metadata.

AdaCap-IIoT defines authorization as a lifecycle-driven and runtime-adaptive process. It continuously monitors capability use, delegation, trust changes, failed requests, and information flows. When risk increases, it can shorten capability lifetimes, strengthen verification, restrict access, suspend delegation, or trigger revocation, thereby extending blockchain-enabled CapBAC beyond static token verification.

1.1. Contribution

This work extends our previous study on blockchain-enabled CapBAC in IIoT environments (Anagnostopoulou et al., 2025). We deepen the analysis of existing models and use the identified limitations to propose AdaCap-IIoT as a reference architecture for adaptive blockchain-enabled CapBAC in IIoT. The main contributions of this work are summarized as follows:

1. **Extended analysis:** We extend the comparative analysis of blockchain-enabled CapBAC models by examining additional dimensions that are critical for IIoT, including capability lifecycle coverage, runtime adaptivity, privacy-preserving verification, revocation robustness, delegation control, and threat coverage.
2. **Design gaps:** We identify design gaps in existing approaches, indicating that most models remain access-centric and provide limited support for post-authorization information-flow monitoring, adaptive risk response, and unified privacy-aware lifecycle management.
3. **Reference architecture:** We propose AdaCap-IIoT, a reference architecture for adaptive blockchain-enabled CapBAC in IIoT environments, integrating distributed trust anchoring, edge-side authorization, zero-knowledge-based capability verification, modular smart-contract responsibilities, dynamic risk evaluation, and adaptive revocation.

4. **Lifecycle model:** We define a lifecycle-driven authorization workflow that manages capability issuance, binding, verification, delegation, attenuation, monitoring, revocation, auditing, and recovery based on context, operational risk, and observed information flows.

1.2. Structure

The remainder is organized as follows. Section 2 presents the research methodology used to identify relevant blockchain-enabled CapBAC models. Section 3 outlines the IIoT operational context and introduces the theoretical background of CapBAC, blockchain technology, and the capability lifecycle. Section 4 reviews the selected blockchain-enabled CapBAC approaches. Section 5 presents the multi-dimensional comparative analysis. Section 6 introduces the AdaCap-IIoT reference architecture, including its design requirements, layered architecture, operational components, and dynamic access-control workflow. Section 7 discusses security assumptions, privacy considerations, deployment feasibility, and limitations. Finally, Section 8 summarizes the main findings and outlines future directions.

2. Research methodology

In order to conduct a transparent and reproducible systematic literature review of the approaches that integrate the concepts of CapBAC and blockchain technology, we utilized the PRISMA statement (Page et al., 2021). The four steps that define PRISMA are: (1) plan and define the scope, (2) identify papers based on targeted keywords, (3) assess the selected papers, and (4) extract data, and present the findings.

2.1. Research objectives and strategy

The first and most important step was to define a set of research questions that we aimed to answer through this manuscript. The research questions, along with their corresponding goals, are presented in Table 1. Based on these questions, we constructed a comprehensive keyword string that employed in the search engines in order to retrieve relevant works (see Table 2). We used several widely known academic search systems in order to retrieve relevant work, including Google Scholar, Scopus, and Web of Science. The systematic literature search was carried out from September to December 2024.

The search query resulted in the significant number of 447 publications. For the evaluation of all these publications we established and applied the following sets of inclusion and exclusion criteria. The inclusion criteria include: (a) relevance of title, (b) evaluation of the gathered material based on abstract and introduction, and (c) full-text reading of each article and publication.

The exclusion criteria include: (i) research papers, book chapters, and scientific articles without peer-review processes, (ii) articles or papers not written in English, (iii) publications missing abstracts and introduction as these sections are crucial for preliminary evaluation of relevance, (iv) irrelevant articles that initially seemed to be in context, but after closer review they were out-of-scope, (v) articles and publications from organizations without a valid national or international status, and (vi) unreferenced publications or unknown authors that were not members of relevant scientific communities. Criterion vi refers to publications not published in any scientific venue and are not referenced, cited, or otherwise validated from other technical whitepapers, reports, or research publications. It is important to clarify that this does not depend on whether a publication is included in paid venues; it just eliminates the possibility of fake or plagiarized content.

Table 1
Overview of the research questions and their goals.

Research question	Goal
RQ1. How does CapBAC model operate in IIoT? What are its key security vulnerabilities?	This RQ explores the key vulnerabilities and challenges of CapBAC model, including scalability and unauthorized data access.
RQ2. How does integrating blockchain into CapBAC enhances security in IIoT environments?	This RQ investigates how blockchain enhances the security of CapBAC models in IoT environments.
RQ3. What are the key challenges and limitations of using blockchain in CapBAC for IIoT?	This RQ identifies practical limitations of implementing blockchain in CapBAC, such as scalability, and energy consumption.
RQ4. Which models have researchers proposed to address the main vulnerabilities?	This RQ examines CapBAC and architectures proposed to address IoT vulnerabilities, highlighting innovative approaches.
RQ5. What performance evaluation metrics are used for the developed models?	This RQ explores the key metrics for evaluating the performance and effectiveness of CapBAC models.
RQ6. How are these schemes and models validated?	This RQ investigates the validation methodologies for these CapBAC models.

Table 2
Keyword query that used at search.

("Capability-Based Access Control" OR "CapBAC") AND ("Industrial Internet of Things" OR "IIoT") AND ("blockchain" OR "blockchain integration" OR "blockchain for security") AND ("vulnerabilities" OR "access control weaknesses" OR "challenges" OR "limitations" OR "Models" OR "Schemes" OR "performance" OR "evaluation criteria" OR "evaluation" OR "validation")

2.2. Selection of studies and analysis

We introduce Fig. 1, which shows the PRISMA flow diagram, as a visual representation of the research selection procedure. The number of studies found, screened, included, and excluded at each review stage is depicted in this diagram. First, we eliminated 20 documents that were written in languages other than English. Next, we eliminated the 137 documents that were duplicates. From the remaining 290 documents, we eliminated a significant number of documents (222 documents) based on their titles and abstracts. Finally, we excluded 49 documents after conducting full-text reading. In the end, we selected 19 papers for our review. Ten of them examine blockchain-enabled CapBAC approaches. The remaining nine papers played an important role in shaping our evaluation criteria. We also used additional literature for peripheral information of our work. However, we did not take them into account to the number of included files as they were not directly associated with our research questions.

3. Theoretical background

This section provides the theoretical foundation, emphasizing on the core concepts of capability-based access control and blockchain technology.

3.1. IIoT operational context and access-control implications

The Industrial Internet of Things extends IoT connectivity to industrial environments in which networked computation is closely coupled with physical processes. Typical IIoT deployments combine sensors, actuators, programmable controllers, industrial gateways, edge services, supervisory platforms, and cloud-based applications. These components exchange telemetry, control commands, maintenance information, and operational data across shop-floor, edge, enterprise, and external service domains (Ahmed et al., 2023; Latif et al., 2021).

Compared with many consumer-oriented IoT deployments, IIoT environments generally impose stricter requirements for availability, predictable response times, operational continuity, and safety. They

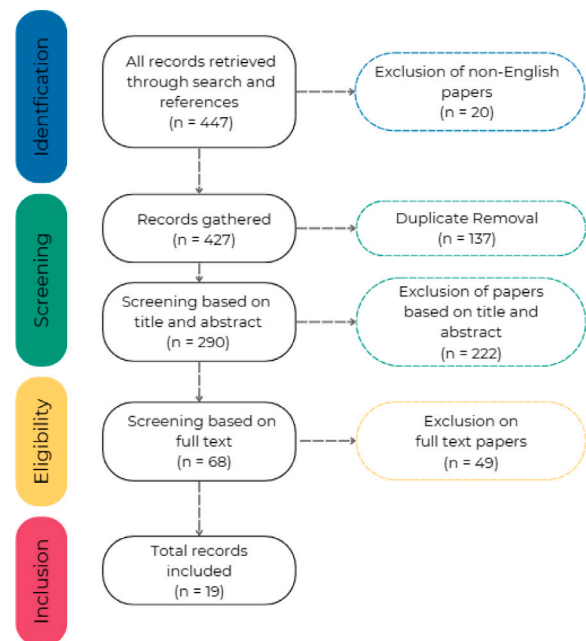


Fig. 1. PRISMA flowchart.

also combine resource-constrained endpoints with long-lived or legacy equipment, heterogeneous communication protocols, multiple network zones, and components managed by different administrative domains. Consequently, unauthorized access or delayed revocation may affect not only data confidentiality but also equipment operation, production continuity, and the safety of physical processes. At the same time, direct interaction with a blockchain may be impractical for constrained devices or latency-sensitive operations (Kumar et al., 2022; Wang et al., 2020).

These characteristics directly influence access-control design. IIoT authorization should support fine-grained and context-aware permissions, low-latency local enforcement, controlled cross-domain delegation, rapid revocation, and auditable lifecycle management. Moreover, authorization should not end when access is granted, since data and control commands may subsequently propagate through devices, gateways, services, and administrative domains. These requirements motivate the combination of capability-based authorization, ledger-based trust anchoring, edge-side enforcement, and post-authorization information flow monitoring examined in this work.

3.2. Capability-based access control

CapBAC model has emerged as a promising approach for managing access rights in distributed systems, particularly suited for the IoT environment. Unlike traditional access control models that rely on centralized access control lists (ACLs), CapBAC distributes access rights directly to subjects in the form of capability tokens (Hernández-Ramos et al., 2013; Nakamura et al., 2021a). A capability token is a set of access rights granted to a subject. Each access right is typically represented as a pair (device, operation), indicating that the subject is allowed to perform a specified operation on the given device. In IoT, operations are most likely actions like GET, PUT, POST, and DELETE (Nakamura et al., 2021a).

The key components of the CapBAC model are subjects (users, applications, or other entities that request access to resources), objects (resources or devices), capability tokens (sets that encapsulate access rights), and device owners. Firstly, the device owner issues a capability token for the device to a subject. Then the subject sends an access request to the device with the capability token that received from the owner. The device then validates the capability token and informs the subject whether the request was denied or approved (Nakamura et al., 2021a).

3.3. Blockchain

Blockchain relies on public-key cryptography, cryptographic hashing, and decentralized consensus to maintain a replicated ledger across distributed nodes. It operates as a distributed ledger in which nodes in a peer-to-peer network maintain consistent copies of the ledger state. Transactions are validated and appended to the ledger through a consensus process, ensuring consistent updates across participating nodes (Kumar et al., 2022; Latif et al., 2021). A blockchain can be described in terms of three core components: blocks, the chain structure, and the supporting network. Blocks consist of a header and a body containing cryptographically signed transactions. The header includes the previous block's hash, a timestamp, a nonce, and a Merkle root. Blocks are linked sequentially, starting from the genesis block, with each block's identifier derived from its hash (Latif et al., 2021; Wang et al., 2020; Lesavre et al., 2020). In the context of this work, blockchain primarily supports decentralized trust establishment, tamper-evident records, auditability, and automation based on smart contracts.

3.4. Capability lifecycle

In CapBAC systems, authorization should not be limited only in the verification of a capability token at access time. A capability follows a broader lifecycle that starts with issuance and continues through binding, verification, use, delegation, attenuation, revocation, expiration, auditing, and possible recovery. These phases are presented in Fig. 2.

This lifecycle perspective is important in IIoT environments, where device behavior, operational context, and risk conditions may change over time. The phases of the capability lifecycle are introduced in Table 3.

4. Blockchain-enabled CapBAC models for IIoT

This section introduces ten approaches that combine CapBAC with blockchain technology to improve security and efficiency in IIoT systems.

4.1. CapBAC (using public Ethereum)

Liu et al. (2021) proposed a decentralized CapBAC model for IoT devices using blockchain technology and decentralized identifiers (DIDs). Each participant (human or IoT device) has at least one unique DID, and access control is managed through capability tokens and credentials. The system consists of three modules: (i) identifier, (ii) ownership,

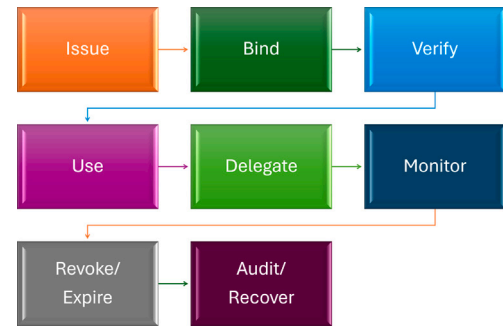


Fig. 2. Phases of capability lifecycle.

Table 3

Capability lifecycle phases.

Lifecycle phase	Meaning
Issuance	Creation of a capability by an authorized issuer, such as a device owner, domain authority, or delegated management entity.
Binding	Mapping of the capability with specific security parameters, such as subject, object, operation, validity interval, context, domain, or device identity.
Verification	Verification that the capability is authentic, valid, non-expired, non-revoked, and applicable to the requested operation.
Delegation	Transfer of access rights from one authorized entity to another, either within the same domain or across different administrative domains.
Attenuation	Restriction of delegated rights so that the delegated capability grants fewer or equal privileges compared with the original capability.
Revocation	Invalidation of a capability before its natural expiration, usually due to policy changes, compromise, misuse, or administrative decision.
Recursive revocation	Propagation of revocation to capabilities derived from the original capability through delegation chains or delegation graphs.
Expiration	Automatic invalidation of a capability after a predefined time interval, usage limit, or contextual condition.
Auditability	Ability to trace and verify lifecycle events, such as issuance, verification, delegation, revocation, and policy updates.
Recovery	Handling of exceptional conditions, such as key loss, device compromise, issuer compromise, inconsistent revocation state, or restoration after failure.

and (iii) capability management, each interacting with on-chain smart contracts. The DID Registry links DIDs to DID Documents (DDOs) which are stored on-chain enabling registration, resolution, updates, revocation, and recovery. Device owners create ownership tokens and credentials stored in a Device Ownership Credential Registry, ensuring only authorized devices interact with requesters. The capability tokens and credentials manage access rights. Requesters send capability tokens to edge servers for verification, which then grant or deny access. The model is evaluated using an IoT device rental use case on a university campus. Authors implemented a proof-of-concept prototype using Node.js and the Parity consortium blockchain, with smart contracts written in Solidity. Security evaluation demonstrates protection against unauthorized access, data manipulation, and system recovery issues. Performance evaluation shows blockchain operations take around 10 s, while non-blockchain operations are faster. The model eliminates single points of failure, prevents device tracking, and provides a scalable, lightweight solution for IoT access control. Its comprehensive architecture and detailed system interaction address gaps in existing blockchain-based access control solutions.

4.2. CapBAC (using private Ethereum)

Nakamura et al. (2019) proposed a CapBAC scheme for IoT that uses Ethereum smart contracts to provide decentralized and reliable access control. The model employs capability tokens linked to specific actions (e.g., read, write, execute) for each subject–object pair. Smart contracts manage token creation, delegation, revocation, and verification. When a subject requests access, the smart contract verifies the token's validity and access rights. A hierarchical delegation tree represents delegation relationships through parent–child links rooted in the original capability owner, with each delegated capability associated with a single parent. In contrast, the proposed scheme uses a delegation graph, allowing delegation relationships for different actions to be represented through multiple paths. This structure provides greater flexibility in transferring and managing access rights among subjects. Authors evaluated the model by implementing it on a private Ethereum network and analyzing its gas consumption compared to BlendCAC. Gas costs were measured for key functions under different scenarios. They concluded that the proposed scheme consumed less gas for most operations. Token creation had a constant gas cost, unlike BlendCAC's linear increase. Delegation costs were similar to BlendCAC, while revoking a single child's token consumed less gas. However, revocation from all descendants required more gas due to the granular token structure. The evaluation indicated that the proposed model provides more flexible and fine-grained access control at similar or lower computational costs. Limitations include low privacy due to the absence of encryption and a lack of real-world IoT scenario testing.

4.3. CapChain

Le and Mutka (2018) proposed CapChain, a blockchain-based access control framework for IoT environments. Device owners generate and encrypt capabilities, which are transferred through anonymous transactions on a public blockchain. This framework allows users to share and delegate access rights while protecting privacy. CapChain employs techniques from anonymous cryptocurrency systems, such as (i) ring signatures, which allow a signer to demonstrate membership in a group without revealing which group member produced the signature and (ii) capability commitments, to hide user identities and capability details. Key features include automatic capability expiration, revocation of delegated rights, and management of multiple capabilities through a single master account. CapChain also implements a deterministic sub-address system to support anonymous transactions while ensuring traceability for the original delegator. Authors employ a similar approach to FairAccess in order to transfer authorization tokens through transactions. However, CapChain avoids embedding access control policies in token transactions, preserving privacy by keeping sensitive device and user information off the public blockchain. A proof-of-concept testbed demonstrates its ability to securely manage access rights while maintaining privacy. CapChain addresses resource limitations in IoT devices by allowing them to rely on a local proxy for blockchain queries. It enhances privacy by obfuscating user identities, capability details, and transaction depths, solving key privacy challenges in public blockchains. Moreover, this approach enables scalability by allowing users to manage capabilities across multiple domains through a single account. Authors evaluated CapChain under an adapted proof-of-work consensus from Monero. They integrated techniques from anonymous cryptocurrencies, and prove that CapChain provides a privacy-preserving access control solution for IoT environments.

4.4. CB2FAC

Sun et al. (2019) proposed CB2FAC, a fine-grained and flexible capability-based access control model using blockchain. CB2FAC supports dynamic authorization and fast revocation through a new capability token structure and strict authorization rules. The model uses

an authorization tree and a capability revocation list for efficient privilege management, encrypts tokens with AES for secure transmission, and employs a strict verification process. CB2FAC is built on the Hyperledger Fabric blockchain platform and consists of three main components: (i) a Service Domain for policy enforcement, (ii) an Application Domain for subject–object interactions, and (iii) smart contracts for managing subjects, resources, and capabilities. Smart contracts mediate between users and the blockchain, handling tasks such as subject registration, resource management, and token manipulation. This architecture ensures fine-grained access control and fast privilege revocation, while it reduces revocation time through the capability revocation list. To evaluate CB2FAC, authors conducted simulation experiments on a virtual machine setup with Hyperledger Fabric. Tests included granting, revoking, and verifying capability tokens, focusing on latency and throughput under various transaction request rates. Results indicated that CB2FAC achieved high throughput and low latency in large request scenarios while maintaining secure and reliable access control. Authors concluded that CB2FAC is suitable for practical applications and suggested that there is need to improve the encryption algorithm to enhance security.

4.5. IoT-CCAC

Bouras et al. (2021) proposed IoT-CCAC, a blockchain-based access control model for IoT consortium networks. IoT-CCAC organizes access control data into assets (physical devices), services (collaborative applications), and profiles (asset representations within services) to improve flexibility and granularity. It introduces statements as documents defining access permissions, which can be granted as capability tokens to individuals or groups. The model supports group capability tokens and provides a membership service with varying permissions. It also integrates a blockchain-based database that combines blockchain security with the performance of traditional databases. This approach aims to address the scalability and growth needs of IoT. To evaluate the model, authors implemented a proof-of-concept prototype simulating a waste management scenario in a smart city. The prototype was built using Python, Flask, JWT Crypto Library, and BigchainDB. Authors chose Tendermint as the consensus protocol. The evaluation measured communication and computation costs for creating assets, profiles, services, and statements, as well as scalability through bulk transaction tests. Results indicated that IoT-CCAC performed well in security and scalability. Finally, they achieved faster authentication by efficient database querying.

4.6. BlendCAC

Xu et al. (2018) proposed a blockchain-enabled decentralized capability-based access control model for IoT systems. BlendCAC is designed to provide a scalable, and lightweight access control solution. The Identity-based capability tokens specify which subjects have access to specific objects. The smart contracts handle token generation, validation, and revocation. BlendCAC also incorporates a federated delegation mechanism, enabling access rights delegation across different security domains. When a subject requests access, the service provider retrieves the token from the smart contract and validates access locally, allowing fine-grained, context-aware decisions. Authors evaluated BlendCAC through a proof-of-concept prototype on a private Ethereum blockchain. Miners acted as cloud servers, fog nodes, and edge nodes. The evaluation focused on the effectiveness in preventing unauthorized access, managing delegation and revocation, computational overhead, and network latency. Results indicated that BlendCAC effectively blocked unauthorized access and efficiently handled delegation and revocation processes. Overall, BlendCAC provides a decentralized and scalable solution to access management challenges in dynamic and heterogeneous IoT environments, while blockchain enhances security and transparency.

4.7. CapBlock

Truong et al. (2022) proposed CapBlock, an IoT access control model integrating distributed CapBAC (DCapBAC) with blockchain. CapBlock uses two smart contracts on a permissioned blockchain: a policy contract for managing and evaluating access control policies and a capability contract for generating and managing tokens. It employs the eXtensible Access Control Markup Language (XACML), a standardized language for expressing and evaluating access-control policies and the DCapBAC approach for specifying tokens. When a user requests access, the system authenticates them, evaluates policies, and generates a capability token if approved, with all actions recorded on the blockchain for auditability. Authors implemented CapBlock using Hyperledger Fabric and evaluated its performance under various configurations, including different network and block sizes. They assessed latency, throughput, and the efficiency of policy registration, evaluation, and token generation. Results indicated that CapBlock improves security and provides efficiency comparable to non-blockchain DCapBAC solutions.

4.8. DTSAC

Liao and Wu (2023) proposed DTSAC, a Dynamic Trust and Smart Contract-based Access Control model, to overcome the limitations of traditional access control. DTSAC uses smart contracts to automate capability token generation, delegation, and verification. The model employs a delegation tree system, with a root tree and subtrees representing delegator-delegatee relationships. This structure simplifies access control management, allowing quick permission revocation and reducing complexity. When a data user (DU) requests access, the smart contract verifies the token and assesses the DU's trust value based on predefined thresholds. Trust is categorized into normal, frequent, and malicious access. DTSAC updates trust values dynamically across multiple trees using both direct trust (on-chain history) and indirect trust (tree relationships), enhancing flexibility and efficiency. Authors implemented DTSAC on the Sepolia Ethereum testnet and evaluated its performance for security, scalability, and dynamic access management. Results indicated that DTSAC improves flexibility in granting and revoking capabilities and strengthens security through two-way dynamic trust evaluation. The model addresses IoT challenges like single points of failure and limited adaptability, providing a scalable and robust solution for distributed environments.

4.9. CDDAC

Li et al. (2021) proposed CDDAC, a blockchain-based IoT Cross-Domain Delegation Access Control Method, to enhance interoperability and security in IoT cross-domain access control. CDDAC uses single-layer capability tokens to represent access rights, reducing size and processing overhead compared to traditional nested tokens. This design simplifies integration with blockchain systems and reduces token complexity. When access is requested, the domain manager verifies the token against policies and creates a delegation topology stored as a hash in a Delegation Trajectory Database (DTDB) on the blockchain. This approach ensures reliability without frequent policy updates on-chain, though smart contract redeployment adds overhead. Cross-domain access requests are handled through inter-domain communication based on the aggregated delegation data. Authors evaluated CDDAC on the Ropsten test network, with their focus on delegation verification speed and decision-making efficiency. The results showed that CDDAC outperformed CapBAC and BlendCAC, achieving faster token verification speeds. The model enhances scalability and usability, providing a robust solution for cross-domain IoT access control and improving security management.

4.10. DCACI

Pinjala and Sivalingam (2019) proposed a Decentralized Lightweight Capability-Based Access Control Framework using IOTA. IOTA is a distributed ledger technology originally designed to support machine-to-machine transactions in IoT environments. In the version employed by DCACI, transactions are recorded in the Tangle, a Directed Acyclic Graph (DAG) in which each new transaction approves previous transactions instead of being appended to a linear chain of blocks (IOTA Foundation, 2025). This structure supports fee-free transactions and was intended to improve scalability for frequent interactions among IoT devices. The framework uses the Winternitz signature scheme for stronger transaction security and IOTA's Masked Authenticated Messaging (MAM) for privacy and integrity of capability tokens, which encapsulate user permissions for accessing resources. Domain owners manage capability tokens on the Tangle and use IOTA seeds to generate private keys and addresses for transactions. When users request tokens, they should specify the resource and action. This request will be evaluated by domain owners. The approved tokens are context-aware, since they embed information like time or location for access. Users without an IOTA seed can participate but need one to delegate access rights. Authors evaluated DCACI through a proof-of-concept implementation on resource-constrained devices. The performance metrics indicated that the framework supports access control for millions of IoT devices with low latency and high transaction throughput. Its fee-less nature makes it ideal for environments with frequent device interactions.

5. Multi-dimensional comparative analysis

This section provides a multi-dimensional comparative analysis of the reviewed blockchain-enabled CapBAC models. Instead of focusing only on general performance and security criteria, the analysis considers several complementary dimensions: baseline IIoT suitability, capability lifecycle coverage, runtime adaptivity, privacy preservation, revocation and delegation robustness, and threat coverage. This evaluation highlights key limitations in existing approaches and defines the design requirements that motivate AdaCap-IIoT.

Each model is assessed qualitatively using a four-value notation: (i) H denotes strong support, (ii) P denotes partial support, (iii) L denotes limited support, and (iv) N/A denotes that the corresponding property is not clearly reported or cannot be reliably inferred from the original study. This notation allows us to compare heterogeneous models without assuming that all studies report the same implementation details, performance metrics, or validation evidence.

5.1. Baseline comparison of blockchain-enabled CapBAC models

The baseline evaluation compares the reviewed blockchain-enabled CapBAC models using twelve criteria grouped into four categories: performance metrics, blockchain features, implementation effort, and security and privacy. These criteria provide an initial comparative layer for assessing whether each model can support core IIoT requirements. Below, we briefly introduce these groups along with their corresponding evaluation criteria.

Group 1: Performance Metrics. Assesses operational efficiency and reliability under realistic IIoT workloads. It includes:

- **Scalability.** The model's ability to handle increasing numbers of devices, users, and access requests in IIoT environments (Pal and Jadidi, 2021).
- **Performance.** The model's ability to support time-sensitive industrial operations, where delays in data transmission or processing may affect productivity and efficiency (Ahmed et al., 2023).
- **Efficiency.** The computational, memory, bandwidth, and communication overhead of the model, especially for resource-constrained IIoT devices (Ahmed et al., 2023).

Table 4
Baseline comparison of blockchain-enabled CapBAC models across IIoT-oriented criteria.

Criterion	Eth-Priv	Eth-Pub	CapChain	CB2FAC	IoT-CCAC	BlendCAC	CapBlock ^a	DTSAC	CDDAC	DCACI
Group 1: Performance metrics										
Scalability	H	P	H	H	H	H	H	H	H	H
Performance	H	P	P	H	H	H	P	H	H	P
Efficiency	H	H	P	P	H	H	H	H	H	H
Low-latency support	P	L	P	L	P	P	P	N/A	L	L
Throughput	N/A	N/A	N/A	H	P	N/A	P	N/A	H	H
Group 2: Blockchain features										
Degree of decentralization	L	P	H	P	P	L	P	N/A	H	N/A
Consensus mechanism	H	P	P	L	H	P	L	P	P	P
Smart contracts adoption	P	L	N/A	P	N/A	H	H	H	H	N/A
Group 3: Implementation effort										
Implementation simplicity	H	P	L	L	P	P	L	H	L	L
Interoperability	P	P	N/A	H	P	P	H	P	P	P
Group 4: Security and privacy										
Security guarantees	N/A	H	N/A	H	H	P	H	H	H	H
Privacy protection	L	H	H	N/A	P	P	H	N/A	L	H

Model abbreviations: Eth-Priv = CapBAC using private Ethereum; Eth-Pub = CapBAC using public Ethereum.

Notation: H = strong support; P = partial support; L = limited or indirect support; N/A = not clearly reported.

^a CapBlock is retained in the comparison for completeness, but its evidence base is limited by the retraction status of the corresponding publication.

- **Latency.** The time required to process an access request and return a response. Low latency is essential for reliable and timely industrial operation (Kumar et al., 2022).
- **Throughput.** The number of access requests the model can process per unit of time, indicating its ability to support concurrent IIoT interactions without bottlenecks (Kumar et al., 2022).

Group 2: Blockchain Features. Examines blockchain-specific features that support decentralized, automated, and auditable access control.

- **Degree of Decentralization.** Evaluates the model's reliance on centralized authorities and its resilience to single points of failure (Kumar et al., 2022).
- **Consensus Mechanism.** Assesses whether the adopted consensus algorithm is suitable for secure, scalable, and energy-efficient IIoT operation (Lashkari and Musilek, 2021; Polat and Göcmenoglu, 2022).
- **Smart Contracts Adoption.** Assesses the use of smart contracts for automated access-control enforcement, especially under complex policy conditions (Kumar et al., 2022).

Group 3: Implementation Effort. Assesses the effort required to implement, maintain, and integrate each model.

- **Complexity.** Examines the model's architectural, algorithmic, and protocol complexity. Lower complexity improves implementation and maintenance (Ahmed et al., 2023).
- **Interoperability.** Assesses compatibility with existing IIoT protocols, standards, and devices for integration in heterogeneous industrial environments (Ahmed et al., 2023).

Group 4: Security and Privacy. Assesses security and privacy protection in industrial access control.

- **Security Guarantees.** Assesses robustness against cyberattacks through cryptography, key management, and authentication (Pal and Jadidi, 2021).
- **Privacy Protection.** Assesses data protection during communication and storage, including unauthorized-access prevention and privacy support (Pal and Jadidi, 2021).

Table 4 summarizes the evaluation of the ten reviewed models. The comparison shows that several models achieve strong results in

scalability, efficiency, and security guarantees. However, it also highlights important weaknesses in latency, throughput, decentralization, smart-contract adoption, and privacy protection.

CDDAC, CB2FAC, and DCACI show the broadest baseline coverage. CapBlock also performs well across several dimensions, although its results should be interpreted cautiously because the study has been marked as retracted. IoT-CCAC, BlendCAC, and DTSAC provide more balanced but partial support, whereas the Ethereum-based CapBAC schemes and CapChain show partial coverage due to limited performance evidence, privacy limitations, or insufficient alignment with IIoT operational requirements.

Regarding the criteria, scalability and efficiency are among the strongest dimensions, supporting the claim that blockchain-enabled CapBAC can enable large-scale and resource-aware IIoT access control. However, latency and throughput remain more challenging for real-time industrial use. Blockchain-related features also vary: private or consortium settings improve management and performance but reduce decentralization, while smart contracts are not always central to enforcement or automation.

The results regarding security and privacy indicate that strong security mechanisms do not necessarily make a model suitable for dynamic IIoT environments. Several models provide robust cryptographic or access-control mechanisms, but privacy protection remains inconsistent, especially when authorization metadata, or access patterns are exposed through ledger-side operations. The comparison also highlights a trade-off between stronger security guarantees and increased architectural or operational complexity.

This baseline comparison identifies general strengths and weaknesses, but it does not fully assess how each model manages the capability lifecycle, adapts authorization decisions at runtime, or controls information flows after access has been granted.

5.2. Capability lifecycle coverage

To evaluate blockchain-enabled CapBAC models more precisely, we examine how each approach supports the main phases of the capability lifecycle. This is important because CapBAC is not limited to the verification of a token at access time. In dynamic IIoT environments, capabilities require lifecycle management from issuance and verification to delegation, attenuation, revocation, auditing, and recovery. The reviewed models address selected lifecycle phases, but they rarely provide comprehensive lifecycle coverage. Table 5 describes the capability lifecycle coverage of the reviewed blockchain-enabled CapBAC

Table 5
Capability lifecycle coverage of blockchain-enabled CapBAC models.

Model	Issuance	Binding	Verification	Delegation	Attenuation	Revocation	Recursive revocation	Expiration	Auditability	Recovery
CapBAC using public Ethereum	H	H	H	P	L	P	N/A	N/A	H	P
CapBAC using private Ethereum	H	H	H	H	P	H	H	N/A	P	N/A
CapChain	H	P	P	H	P	H	P	H	P	N/A
CB2FAC	H	H	H	H	P	H	P	N/A	P	N/A
IoT-CCAC	H	H	P	P	P	P	N.R.	N/A	H	N/A
BlendCAC	H	H	H	H	P	H	P	N/A	P	N/A
CapBlock ^a	H	H	H	P	P	P	N/A	P	H	N/A
DTSAC	H	H	H	H	P	H	H	N/A	H	N/A
CDDAC	H	H	H	H	L	P	N/A	N/A	H	N/A
DCACI	H	H	P	P	P	P	N/A	P	H	N/A

Notation: H = strong support; P = partial support; L = limited or indirect support; N/A = not clearly reported.

^a CapBlock is retained in the comparison for completeness, but its evidence base is limited by the retraction status of the corresponding publication.

Table 6
Descriptive summary of capability lifecycle coverage.

Model	H	P	L	N/A	Score
CapBAC using public Ethereum	4	3	1	2	63.3%
CapBAC using private Ethereum	6	2	0	2	73.3%
CapChain	4	5	0	1	73.3%
CB2FAC	5	3	0	2	70.0%
IoT-CCAC	3	4	0	3	56.7%
BlendCAC	5	3	0	2	70.0%
CapBlock ^a	4	4	0	2	66.7%
DTSAC	7	1	0	2	76.7%
CDDAC	5	1	1	3	60.0%
DCACI	3	5	0	2	63.3%

Notation: H = strong support; P = partial support; L = limited or indirect support; N/A = not clearly reported.

^a CapBlock is retained in the comparison for completeness, but its evidence base is limited by the retraction status of the corresponding publication.

models. The comparison shows that most approaches explicitly support issuance, binding, verification, delegation, and revocation, whereas attenuation, recursive revocation, expiration, and recovery remain less consistently addressed.

To provide a thorough view of the detailed lifecycle matrix, Table 6 provides a descriptive summary of capability lifecycle coverage per model. Specifically, the table counts the number of strong, partial, limited, and not clearly reported lifecycle phases for each approach. Then, we calculate an indicative lifecycle coverage score. For this purpose, the qualitative notation is mapped to numerical values as follows: H is assigned 3 points, P is assigned 2 points, L is assigned 1 point, and N/A is assigned 0 points. Since each model is evaluated across ten lifecycle phases, the maximum possible score is 30 points. Therefore, the final lifecycle coverage score is calculated as $(3H + 2P + 1L + 0N/A)/30$. The result is expressed as a percentage to make the comparison easier to interpret.

This score is a descriptive indicator rather than an absolute ranking of the models. The reviewed studies differ in scope, implementation detail, and reporting completeness. Therefore, this score provides a compact way to summarize how completely each approach addresses the capability lifecycle and to highlight lifecycle areas that remain insufficiently covered across existing blockchain-enabled CapBAC models.

5.3. Runtime adaptivity and flow-aware control

Lifecycle coverage alone does not imply runtime adaptivity. A model may support issuance, verification, delegation, and revocation while still relying on static access-control decisions. Since device behavior, context, and information flow risk may change after capability issuance or access approval, blockchain-enabled CapBAC models should also be evaluated for runtime adaptivity and post-authorization information flow monitoring.

Table 7 compares the reviewed models in terms of adaptivity and runtime awareness. This criterion captures whether a model can update its authorization behavior according to changing trust, context, or risk conditions. Post-authorization flow-aware control was also examined as part of the analysis and refers to whether a model monitors or constrains information flows after access has been granted. This is especially important in IIoT environments, because a subject may hold a valid capability but still propagate accessed data through unauthorized devices, gateways, services, or domains. However, none of the reviewed models explicitly reports such functionality. Since this aspect does not distinguish among the models, it is discussed as a common gap rather than represented as a separate table column.

The comparison shows that most models remain primarily access-centric. They focus on verifying whether a subject holds a valid capability for a requested operation, but they do not continuously evaluate how the subject behaves after authorization. For example, the Ethereum-based CapBAC schemes, CapChain, and IoT-CCAC provide useful mechanisms for capability issuance, verification, delegation, or revocation, but they provide limited evidence of runtime adaptation. In these approaches, capabilities are usually verified as static access tokens at request time, rather than managed as dynamic authorization objects whose validity, scope, and delegation rights can evolve according to observed behavior.

Some models provide partial adaptivity. CB2FAC supports fine-grained authorization and revocation, but its adaptation is mainly revocation-oriented rather than risk-aware or flow-aware. BlendCAC introduces context-aware access decisions and decentralized capability management, but it does not extend this logic to post-authorization information flow control. CDDAC provides strong cross-domain delegation and efficient verification, but it offers limited adaptive response to changing flow-based risk. DCACI is lightweight and context-aware through IOTA-based capability management, but it does not provide a complete adaptive lifecycle model.

Finally, DTSAC provides the strongest support for runtime awareness because it introduces dynamic trust evaluation. It can adjust access-control behavior according to trust values derived from direct and indirect trust information. Nevertheless, DTSAC still does not fully integrate privacy-preserving capability verification or information flow monitoring. As a result, even the most adaptive reviewed model remains focused on trust-aware access decisions rather than post-authorization information flow monitoring.

The comparison shows that the reviewed blockchain-enabled CapBAC models provide limited support for flow-aware control. This is critical in IIoT, where industrial data may propagate across devices, gateways, services, and domains after access has been granted. Therefore, adaptive CapBAC should not stop at capability verification by monitoring information flows and use detected risks to restrict, suspend, revoke, or renew capabilities.

Table 7
Runtime adaptivity of blockchain-enabled CapBAC models.

Model	Adaptivity/runtime awareness	Main observation
CapBAC using public Ethereum	L	Provides DID-based capability management and blockchain-based verification, but adaptivity and post-authorization monitoring are not central.
CapBAC using private Ethereum	L	Supports token creation, delegation, revocation, and verification, but remains largely static and does not address information-flow evolution.
CapChain	L	Emphasizes privacy-preserving capability transfer and expiration, but offers limited runtime adaptation.
CB2FAC	P	Provides great support in fine-grained authorization and revocation, but adaptation is mainly revocation-oriented rather than risk-aware or flow-aware.
IoT-CCAC	L	Supports flexible capability statements and group access, but provides limited evidence of adaptive runtime decision-making.
BlendCAC	P	Provides decentralized capability management and delegation with some context-aware access decisions, but lacks post-authorization flow control.
CapBlock ^a	P	Separates policy and capability logic and supports auditability, but its evidence should be interpreted cautiously if the corresponding study is marked as retracted.
DTSAC	H	Introduces dynamic trust evaluation, but does not fully integrate privacy-preserving capability verification or information-flow monitoring.
CDDAC	P	Provides great support in cross-domain delegation and efficient verification, but provides limited privacy protection and limited adaptive flow-based response.
DCACI	P	Lightweight and context-aware through IOTA-based capability management, but lacks a complete adaptive lifecycle model.

Notation: H = strong or explicit support; P = partial support; L = limited or indirect support.

^a CapBlock is retained in the comparison for completeness, but its evidence base is limited by the retraction status of the corresponding publication.

5.4. Privacy, revocation, and threat coverage

Privacy, revocation, and threat coverage are critical dimensions for evaluating blockchain-enabled CapBAC models in IIoT environments. The baseline comparison already shows that privacy protection is limited across the reviewed models. However, privacy cannot be examined only as a general security feature. In blockchain-enabled access control, critical information may be exposed not only through plaintext capability contents, but also through authorization metadata, transaction patterns, or repeated interactions among subjects, objects, and domains.

Table 8 evaluates each model in terms of privacy protection, revocation and delegation robustness, and threat coverage. These dimensions capture whether a model limits metadata exposure, supports controlled delegation and effective revocation, and addresses key IIoT access-control threats such as unauthorized access, token misuse, compromised entities, privacy leakage, and post-authorization abuse.

The comparison shows that privacy-oriented models, such as CapChain and DCACI, provide stronger mechanisms for hiding capability-related information, but they do not fully address adaptive revocation or runtime threat response. In contrast, models such as CB2FAC and CDDAC provide stronger revocation or delegation mechanisms, but they offer weaker protection against operational metadata leakage. DTSAC provides stronger threat coverage because it introduces dynamic trust evaluation and can respond to suspicious behavior, but privacy-preserving capability verification is not a primary design objective.

Overall, existing models often improve one dimension while leaving others insufficiently addressed. They support selected lifecycle functions, such as issuance, verification, delegation, or revocation, but rarely combine them with privacy-preserving verification and adaptive risk-aware decisions. This gap is critical in IIoT, where compromised

devices may misuse valid capabilities and ledger transparency may expose sensitive operational patterns. Adaptive blockchain-enabled CapBAC should therefore integrate privacy-preserving verification, controlled delegation, efficient revocation, and runtime threat-aware monitoring.

6. AdaCap-IIoT reference model

Based on the findings of the comparative analysis, we propose a conceptual reference architecture, named AdaCap-IIoT, for adaptive blockchain-enabled Capability-Based Access Control in IIoT environments. The purpose of AdaCap-IIoT is to integrate the strongest design features that identified in existing blockchain-enabled CapBAC models, but also address limitations related to static authorization, partial lifecycle support, privacy leakage, revocation, latency, and limited post-authorization control.

AdaCap-IIoT is designed as a synthesis-derived architecture rather than as an isolated access-control proposal. It combines five complementary design principles: (i) privacy-preserving capability verification, (ii) edge-based authorization, (iii) dynamic risk evaluation, (iv) adaptive revocation, and (v) information flow-aware monitoring. Through this combination, the architecture aims to move beyond conventional CapBAC schemes that primarily verify whether a subject holds a valid capability at access time. Instead, AdaCap-IIoT models capabilities as dynamic authorization objects whose validity, scope, delegation rights, and revocation status may evolve according to trust, context, operational risk, and observed information flows.

The architecture is organized into three tiers that separate global trust anchoring, edge-side authorization, and physical device interaction. The first tier records identity, policy, capability, delegation, revocation, and audit commitments. The second tier performs low-latency verification, risk evaluation, and enforcement. Finally, the third tier includes IIoT subjects, objects, gateways, sensors, actuators, and

Table 8
Privacy, revocation, and threat coverage of blockchain-enabled CapBAC models.

Model	Privacy protection	Revocation and delegation robustness	Threat coverage	Main observation
CapBAC using public Ethereum	H	P	P	Good identity protection through DID-based mechanisms, but blockchain latency and limited adaptive revocation remain concerns.
CapBAC using private Ethereum	L	H	P	Strong token lifecycle operations, but privacy is weak because sensitive access-control information may be exposed.
CapChain	H	P	P	Strong privacy orientation, but limited evidence of low-latency revocation and dynamic risk response.
CB2FAC	P	H	P	Strong revocation support, but privacy guarantees and operational metadata leakage are not fully addressed.
IoT-CCAC	P	P	P	Flexible consortium-oriented access control, but privacy and dynamic threat response remain partial.
BlendCAC	P	P	P	Support of decentralized delegation and revocation, but privacy and threat coverage are moderate.
CapBlock ^a	H	P	P	Strong auditability and policy/capability separation, but evidence should be interpreted cautiously if the corresponding study is marked as retracted.
DTSAC	P	P	H	Stronger against insider misuse through dynamic trust, but privacy-preserving verification is not a primary feature.
CDDAC	L	H	P	Strong cross-domain delegation, but weak privacy protection and limited metadata-leakage mitigation.
DCACI	H	P	P	Lightweight and privacy-oriented, but does not fully address adaptive revocation and post-access misuse.

Notation: H = strong support; P = partial support; L = limited or indirect support; N/A = not clearly reported.

^a CapBlock is retained in the comparison for completeness, but its evidence base is limited by the retraction status of the corresponding publication.

services. This separation reduces latency and metadata exposure while preserving blockchain-based auditability and accountability.

6.1. Design requirements

The transition from conventional IoT to IIoT changes the requirements of access control. Industrial environments involve heterogeneous and resource-constrained devices, latency-sensitive processes, cross-domain interactions, and continuously evolving operational conditions. As a result, blockchain-enabled CapBAC for IIoT cannot rely only on static token issuance and verification. Therefore, an effective blockchain-enabled CapBAC architecture for IIoT should satisfy the following requirements (Ahmed et al., 2023).

Low-latency local enforcement. IIoT access-control decisions should be made close to the physical process to avoid the latency and availability constraints of on-chain authorization. The architecture should therefore support edge-side verification and enforcement, while using the ledger mainly for trust anchoring, policy commitments, revocation evidence, delegation records, and auditability (Kumar et al., 2022; Ahmed et al., 2023).

Privacy-preserving capability verification. Capability tokens can reveal sensitive operational metadata, including which devices are accessed, when access occurs, which entities interact, and how frequently industrial resources are queried. A privacy-preserving design should avoid exposing plaintext identities, capability contents, and access patterns whenever possible. Critical information should remain off-chain, while cryptographic commitments or proofs can be used to verify authorization without unnecessary disclosure (Le and Mutka, 2018; Pal et al., 2022).

Dynamic risk and trust awareness. Static capability tokens are insufficient in environments where device behavior and operational risk evolve over time. A valid capability should not imply unconditional trust. The architecture should be able to reduce, suspend, or revoke access when a device becomes suspicious, when request patterns change, when high-risk information flows are detected, or when the requested operation affects a critical asset (Liao and Wu, 2023; Nakamura et al., 2021b; Pal and Jadidi, 2021).

Efficient revocation and delegation control. Delegation is one of the main benefits of CapBAC, but uncontrolled delegation creates serious security risks. The architecture should support capability attenuation, time-bounded delegation, explicit revocation, recursive revocation of delegated rights, and emergency revocation for compromised subjects or domains (Sun et al., 2019; Nakamura et al., 2019; Xu et al., 2018; Li et al., 2021).

Auditability without excessive exposure. Blockchain can strengthen accountability by providing tamper-evident records of policy versions, capability issuance, delegation, revocation, and access events. However, full transparency may expose sensitive industrial information. Therefore, auditability should be implemented using a hash-on-chain and data-off-chain principle, where the ledger stores commitments and proofs rather than raw operational data (Pal et al., 2022).

Post-authorization information flow monitoring. Traditional access control focuses on access-time authorization, but IIoT environments also require post-authorization control. Since data may propagate through devices, gateways, services, and domains after access is granted, adaptive CapBAC should incorporate information flow monitoring to detect suspicious or unauthorized propagation (Nakamura et al., 2021b).

6.2. Layered architecture

AdaCap-IIoT follows a three-tier reference architecture that separates global trust establishment, local authorization execution, and physical device interaction. The architecture uses this separation to: (a) reduce latency, (b) improve scalability, and (c) limit unnecessary exposure of critical operational information. To achieve these goals, AdaCap-IIoT combines a dual-layer distributed ledger, zero-knowledge proofs (ZKPs), dynamic risk evaluation, and modular smart-contract logic to support privacy-preserving, adaptive, and auditable CapBAC in IIoT environments. Fig. 3 presents the static layered architecture of AdaCap-IIoT.

The proposed architecture consists of the following components:

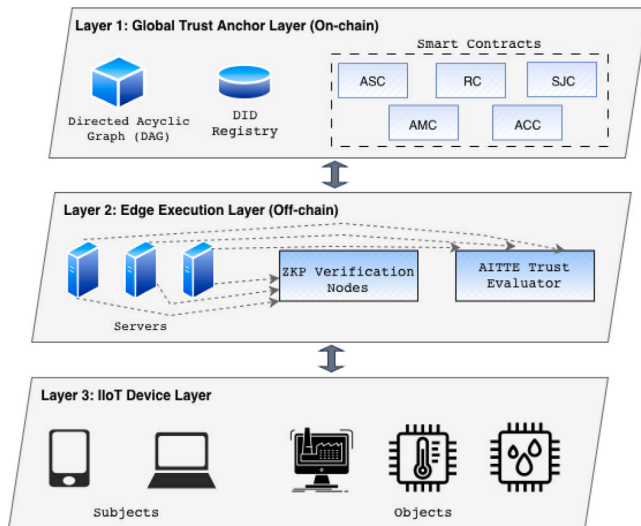


Fig. 3. Static layered architecture of AdaCap-IIoT.

- **Layer 1 (Global Trust Anchor Layer):** This on-chain layer uses a Directed Acyclic Graph (DAG)-based distributed ledger to establish global trust. It hosts the Decentralized Identifier (DID) Registry and the core smart-contract modules, namely Attribute Set Contract (ASC), Registration Contract (RC), State Judgment Contract (SJC), Authority Permission Management Contract (AMC), and Access Control Contract (ACC).
- **Layer 2 (Edge Execution Layer):** This off-chain layer performs the main operational access-control tasks close to the industrial environment. Edge servers host the Zero-Knowledge Proof (ZKP) verification nodes, enabling low-latency authorization and dynamic trust assessment without overloading the main ledger.
- **Layer 3 (IIoT Device Layer):** This layer includes the physical industrial endpoints. The framework classifies these endpoints according to their access-control role as *Subjects*, which request access, and *Objects*, which provide protected resources, services, or data.

6.3. Capability lifecycle

A central design principle of AdaCap-IIoT is that capability management should cover the complete lifecycle of a capability, rather than only the moment of access verification. Conventional CapBAC schemes usually focus on whether a subject can present a valid capability when requesting access. This step remains necessary, but it does not fully address the needs of dynamic IIoT environments, where device behavior, operational context, delegation relationships, and information flow risk may change over time. A capability that appears secure when issued may change later if the subject becomes compromised, the requested operation becomes critical, the capability propagates through delegation, or post-authorization information flows reveal malicious behavior.

AdaCap-IIoT models each capability as a dynamic authorization object. A capability binds a subject to a target resource, an operation, a validity interval, delegation constraints, contextual restrictions, and a policy reference. The architecture does not store the full capability contents directly on the distributed ledger. Instead, the ledger establishes commitments, policy references, revocation evidence, delegation records, and audit trails, while the edge layer performs operational verification and enforcement. This design preserves accountability while reducing unnecessary exposure of critical industrial metadata.

Building on the lifecycle phases introduced in Section 3.3, this subsection explains how AdaCap-IIoT implements this lifecycle-driven

authorization workflow through ledger-anchored commitments, edge-side verification and enforcement, and runtime adaptation of capability scope, duration, delegation rights, and revocation status according to trust, context, operational risk, and observed information flows.

Capability issuance and binding. AdaCap-IIoT issues capabilities through authorized entities, such as domain authorities, asset owners, or delegated management services. The complete capability is delivered through a secure off-chain channel, while the Global Trust Anchor Layer stores only the corresponding commitment and policy reference. Each capability is bound to the relevant security context, including the subject, cryptographic key, target resource, operation, validity interval, domain, and contextual conditions. This binding limits the misuse of copied or stolen capabilities, since a capability remains valid only within its authorized operational scope.

Privacy-preserving verification and edge enforcement. When a subject requests access, the Edge Execution Layer verifies that the subject holds a valid capability without requiring disclosure of the full capability contents. The edge verifier checks the corresponding proof, commitment, expiration status, revocation state, and compatibility between the requested operation and the authorized scope. A successful verification does not automatically imply unrestricted access. The edge enforcement point combines the verification result with the current context and the subject's risk state, and may grant, deny, restrict, or escalate the request. This design keeps frequent access control decisions outside the critical blockchain path and supports latency-sensitive industrial operations.

Delegation, attenuation, and revocation. AdaCap-IIoT supports delegation by ensuring that delegated rights remain explicitly constrained through attenuation. A delegated capability cannot grant more privileges than the original one, and may restrict operations, shorten validity periods, limit accessible resources, prohibit further delegation, or impose stricter contextual requirements. Delegation commitments are established on the ledger to support auditability. Revocation is handled through direct or recursive revocation of delegated capabilities, emergency revocation for compromised entities, and expiration-based invalidation. The edge layer maintains synchronized revocation state, allowing revoked capabilities to be rejected locally without querying the ledger for every request.

Monitoring, audit, and recovery. AdaCap-IIoT extends capability management beyond access-time verification by monitoring access events, data exchanges, failed requests, delegation patterns, and suspicious information flows. These observations update the risk state of subjects, devices, and domains, and can influence future lifecycle decisions, such as renewal, verification strength, delegation rights, or revocation priority. Security-relevant lifecycle events are recorded as audit commitments, while detailed operational evidence remains off-chain to avoid unnecessary exposure of industrial metadata. When compromise, key loss, issuer failure, edge unavailability, or revocation-state inconsistency occurs, AdaCap-IIoT can suspend capabilities, rotate keys, re-register devices, reconstruct audit evidence, and re-issue constrained capabilities.

6.4. Operational components

AdaCap-IIoT relies on three core operational components: (i) privacy-preserving capability verification, (ii) modular ledger logic, and (iii) real-time risk-based information flow monitoring. These components complement the layered architecture since they define how the system verifies capabilities, establish trust and accountability, and adapts access control decisions when risk conditions change.

6.4.1. Privacy-preserving capability tokens via zero-knowledge proofs

Traditional blockchain-enabled CapBAC models may expose critical operational metadata when they record access requests, capability tokens, or authorization events directly on the ledger. Even when

payloads remain encrypted, transaction metadata can reveal which devices interact, when access occurs, how frequently industrial resources receive requests, and which entities participate in operational workflows. AdaCap-IIoT addresses this limitation by using ZKPs: instead of revealing its plaintext identity, blockchain address, or complete capability token, a subject generates a proof demonstrating that it holds a valid capability issued by an authorized entity. The proof also shows that the requested resource, operation, validity interval, and policy conditions match the capability's authorized scope. As a result, AdaCap-IIoT supports authorization and limits the exposure of sensitive identity, capability, and operational information.

AdaCap-IIoT can implement this mechanism through efficient zk-SNARK protocols, such as Groth16. These protocols generate compact proofs and support efficient verification, which makes them suitable for edge-assisted authorization in IIoT environments. AdaCap-IIoT performs proof verification at the Edge Execution Layer, enabling edge servers to validate authorization requests locally instead of forwarding every access decision to the ledger (Groth, 2016; Nitulescu, 2020; Ramezan and Meamari, 2024).

The privacy-preserving verification process follows three main steps:

1. **Proof generation:** The subject generates a zero-knowledge proof that demonstrates the validity of its capability and compliance with the relevant policy conditions, without revealing the full capability contents.
2. **Edge-side verification:** The subject submits the proof to the Edge Execution Layer. Edge servers verify the proof and check the corresponding policy, issuer, expiration, and revocation commitments anchored in the distributed ledger.
3. **Authorization forwarding:** If the proof remains valid and the capability satisfies the requested operation, the edge layer forwards the verification result to the access-control logic for dynamic risk evaluation.

6.4.2. Modular smart contract responsibilities

AdaCap-IIoT avoids a monolithic smart-contract design. A single contract that handles registration, policy management, capability verification, revocation, risk evaluation, and audit logging would increase complexity and make updates difficult. Instead, AdaCap-IIoT separates ledger responsibilities into modular components. Each module manages a specific part of the access-control process, while the edge layer handles frequent operational decisions (Jiang et al., 2023; Molina-Jimenez et al., 2018). Our architecture defines the following ledger modules:

1. **Attribute Set Contract (ASC):** Manages references to the attributes and policy conditions that support access decisions. To avoid exposing critical information, the contract should store commitments, hashes, or references rather than plaintext operational attributes.
2. **Registration Contract (RC):** Manages the registration of subjects, objects, issuers, edge nodes, and administrative domains. It establishes DIDs or identity commitments and allows issuers and verifiers to rely on a consistent trust basis during capability issuance and verification.
3. **State Judgment Contract (SJC):** Maintains or establishes the state information required for trust and risk-aware authorization. AdaCap-IIoT does not require the SJC to perform heavy Bayesian or graph-based calculations on-chain. Instead, the edge layer computes dynamic trust and risk indicators, while the SJC stores compact state commitments, risk-state updates, or verification evidence.
4. **Authority Permission Management Contract (AMC):** Manages authority relationships among issuers, delegators, verifiers, and revocation entities. It records which entities can issue, delegate, revoke, or update capabilities and supports policy-driven changes when trust or risk conditions change.

5. **Access Control Contract (ACC):** Coordinates the ledger-side access control evidence. It records policy and capability commitments, revocation evidence, and audit-relevant authorization outcomes. The ACC does not directly enforce physical access to industrial resources; instead, the edge enforcement point uses the verified results and applicable policies to grant, deny, restrict, or revoke access.

Fig. 4 summarizes the interactions between the modular smart contracts and the edge-side authorization components. During capability verification, the edge layer uses registration information from the RC, attribute and policy commitments from the ASC, authority relationships from the AMC, and capability and revocation evidence from the ACC. The trust and risk evaluator exchanges compact risk-state updates with the SJC, while authorization outcomes relevant to auditing are anchored through the ACC. Frequent verification, risk evaluation, and enforcement operations remain off-chain to avoid placing latency-sensitive access decisions on the distributed ledger.

This modular design improves maintainability and reduces the impact of contract updates. If a policy rule, revocation process, or registration mechanism changes, the architecture can update the corresponding module without redesigning the entire access-control logic. AdaCap-IIoT keeps frequent verification and enforcement tasks at the edge, where the system can meet IIoT latency requirements more effectively.

6.4.3. Real-time risk-based information flow control

Standard capability-based access control systems mainly focus on the initial authorization decision. Once a subject receives a valid capability, the system typically checks whether the subject can access the requested object. However, this access-centric view does not fully address risks since access has been granted. A compromised device may use a valid capability maliciously, or legitimately accessed data may later flow through unauthorized devices, gateways, services, or domains.

AdaCap-IIoT addresses this gap by integrating real-time risk-based information flow monitoring. This component observes how information flows after access has been granted. Instead of handling authorization as a one-time event, AdaCap-IIoT continuously evaluates access behavior, data exchanges, delegation patterns, failed requests, and suspicious flows. The monitoring component can build on the INFFLOW-RT methodology, which models industrial processes as directed dependency graphs. Nodes represent devices, services, or users, while edges represent information flows. This graph-based view allows the architecture to capture both direct and indirect dependencies among IIoT entities (Anagnostopoulou et al., 2026).

For each transaction, authors assess the corresponding information flow using metrics such as data sensitivity, operation type, request legality, and historical behavior. AdaCap-IIoT then applies Bayesian updating and smoothing techniques to recalculate risk estimates incrementally, avoiding full recomputation of the process graph after every transaction. Risk-weighted centrality metrics further help identify nodes that may act as critical propagation points, even when they do not appear structurally central in the network (Anagnostopoulou et al., 2026).

The edge layer uses these risk indicators to adapt capability-management decisions. If the monitoring component detects suspicious behavior, including high-risk flows, or repeated failed attempts, AdaCap-IIoT can shorten capability lifetimes, increase verification requirements, suspend delegation rights, restrict access scope, or trigger revocation. Thus, information flow monitoring feeds directly into the capability lifecycle and enables adaptive authorization beyond the initial access request.

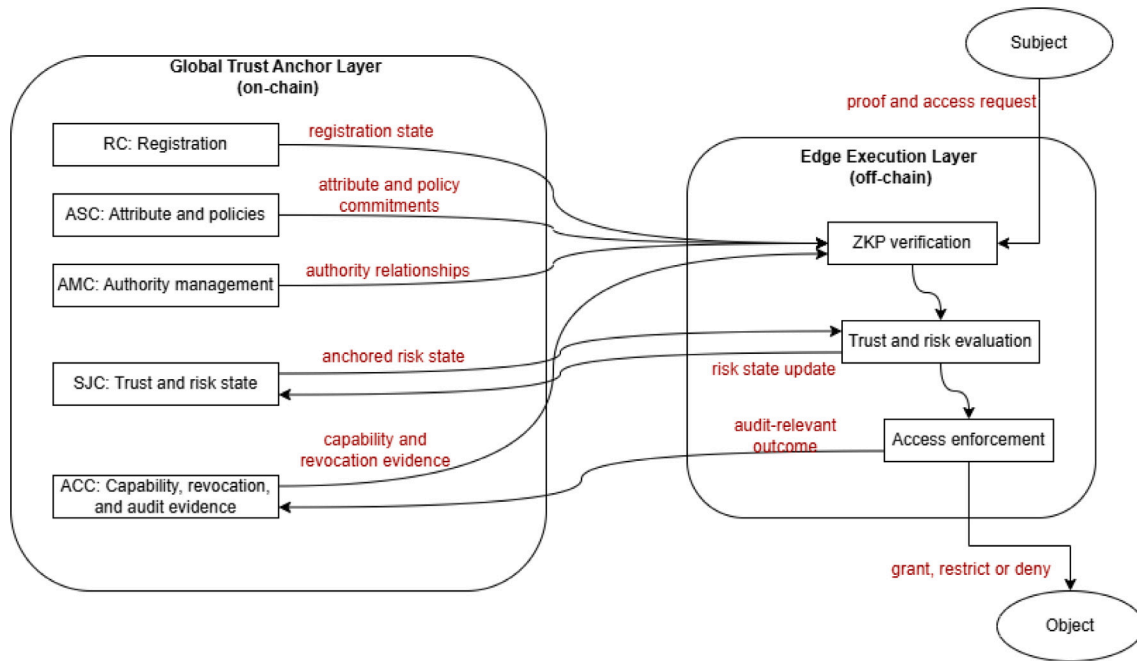


Fig. 4. High-level interactions between the modular smart contracts and the edge-side authorization components of AdaCap-IIoT.

6.5. Dynamic access control workflow

Fig. 5 presents the dynamic sequence of actions and message exchanges that occur when an IIoT device requests access to a resource. The workflow shows how AdaCap-IIoT coordinates the device layer, the edge execution layer, and the global trust anchor layer to support privacy-preserving and adaptive authorization. The access control process follows five main steps:

- **Registration (Step 1):** The requesting device, acting as the *Subject*, registers its DID through the Registration Contract (RC). The Global Trust Anchor Layer stores the corresponding identity commitment, allowing issuers and verifiers to rely on a consistent trust anchor during capability issuance and verification.
- **Privacy-preserving proof generation (Step 2):** Before requesting access, the Subject generates a zero-knowledge proof that demonstrates the validity of a capability without revealing its plaintext identity, blockchain address, or full capability contents. The proof demonstrates that the requested resource, operation, validity interval, and policy conditions match the capability's authorized scope.
- **Edge-side proof verification (Step 3):** The Subject submits the proof to the Edge Execution Layer. Edge servers verify the proof and check the corresponding policy and revocation commitments anchored in the distributed ledger. This allows the architecture to validate authorization locally, without placing every access request directly on-chain.
- **Dynamic trust and risk evaluation (Step 4):** The edge layer evaluates the subject's recent behavior, request context, and risk indicators. The trust evaluator updates the dynamic risk score by considering factors such as suspicious request patterns, inactivity, abnormal behavior, or high-risk information flows. When the risk increases, the architecture can restrict, suspend, or revoke the corresponding capability.
- **Adaptive authorization decision (Step 5):** The access control logic combines the verification result with the dynamic risk assessment. If the proof remains valid and the risk level stays within the accepted threshold, the edge enforcement point grants access to the target *Object*. Otherwise, it denies, restricts, escalates, or revokes access according to the applicable policy.

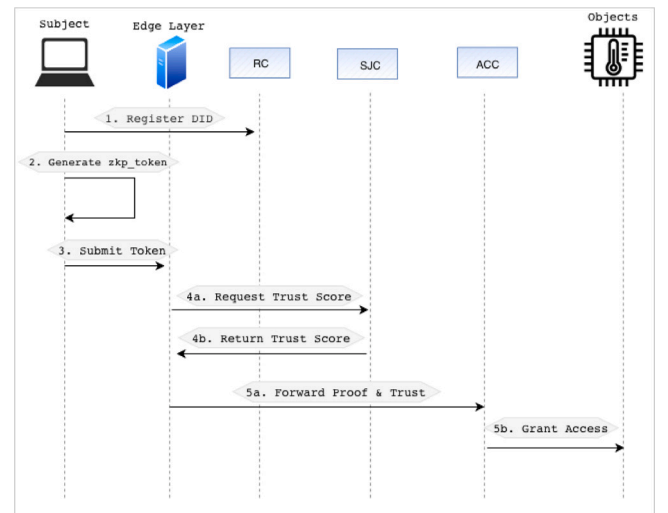


Fig. 5. Dynamic sequence and workflow diagram of the access control process.

This workflow illustrates how AdaCap-IIoT reduces authorization latency by moving frequent verification and enforcement tasks to the edge, while the distributed ledger maintains trust anchors, policy commitments, revocation evidence, delegation records, and audit trails. Moreover, the architecture limits unnecessary disclosure of identities and capability contents and enables adaptive responses when device behavior or information flow risk changes.

7. Discussion

Our analysis shows that blockchain-enabled CapBAC can strengthen distributed authorization in IIoT environments. However, we indicate that existing models do not address all security, privacy, and operational requirements in a unified way. Most reviewed approaches improve selected aspects of the authorization process, such as token issuance, verification, delegation, or revocation. However, they

often remain access-centric and provide limited support for runtime adaptation, privacy-preserving verification, and post-authorization information flow monitoring. AdaCap-IIoT addresses these gaps by combining blockchain-based trust anchoring, edge-side enforcement, zero-knowledge-based capability verification, dynamic risk evaluation, and lifecycle-aware revocation.

This section discusses the security assumptions, privacy implications, deployment feasibility, limitations, and future research directions of the proposed architecture.

7.1. Security assumptions and threat coverage

AdaCap-IIoT assumes that the distributed ledger provides tamper-evident storage for identity commitments, policy references, capability commitments, delegation records, revocation evidence, and audit trails. It also assumes that authorized issuers, edge verifiers, and enforcement points are registered through the corresponding trust-management mechanisms before participating in the access-control process. Under these assumptions, the ledger does not directly enforce every access decision. Instead, it provides a verifiable risk basis that edge nodes can use for local authorization and risk-aware enforcement.

The architecture primarily addresses threats related to unauthorized access, token misuse, compromised subjects, uncontrolled delegation, delayed revocation, metadata exposure, and post-authorization misuse. Unauthorized access is mitigated through capability verification, policy-bound authorization, and edge-side enforcement. Token misuse is reduced by binding capabilities to contextual and cryptographic conditions, such as subject identity, device state, validity interval, and permitted operation. Delegation-related threats are addressed through attenuation and recursive revocation, ensuring that delegated capabilities cannot exceed the privileges of the original capability and can be invalidated when the delegation chain becomes insecure.

AdaCap-IIoT also extends threat coverage beyond the initial access request. In conventional CapBAC schemes, a valid capability may allow a compromised subject to access data and then propagate it through unauthorized channels. AdaCap-IIoT addresses this as a post-authorization risk. Its information flow monitoring component observes access events, data exchanges, failed requests, and suspicious flows, and feeds the resulting risk indicators back into the capability lifecycle. When behavior deviates from expected operation, the architecture can restrict capability scope, shorten validity periods, strengthen verification, suspend delegation, or trigger revocation.

However, AdaCap-IIoT does not eliminate all threats. It does not prevent compromise of an endpoint before access is requested, nor does it guarantee that all malicious flows will be detected in real time. Its effectiveness depends on correct capability issuance, trusted edge enforcement, and reliable risk indicators. Therefore, AdaCap-IIoT should complement broader IIoT security controls, such as device hardening, network segmentation, secure boot, intrusion detection, incident response, and operational security measures.

7.2. Privacy and operational metadata leakage

Blockchain-based access control improves auditability, but it may expose operational metadata. Transaction timing, repeated interactions, subject-object relationships, and access-frequency patterns can reveal industrial workflows, maintenance activities, production dependencies, or critical assets, even when capability contents remain encrypted.

AdaCap-IIoT addresses this issue by keeping full capability contents off-chain and storing only commitments, policy references, revocation evidence, delegation records, and audit proofs on the ledger. This supports accountability without exposing plaintext identities, authorization attributes, or complete capability structures. Zero-knowledge verification further limits disclosure by proving compliance with capability and policy conditions without revealing unnecessary capability details.

Privacy preservation is not only a cryptographic issue. Although zero-knowledge proofs hide capability contents, repeated proof submissions, verifier interactions, revocation checks, and audit events may still reveal behavioral patterns. Therefore, AdaCap-IIoT reduces metadata exposure but should be combined with additional privacy controls, such as batching, pseudonymous identifiers, minimal logging, access-pattern aggregation, and controlled access to audit logs. The appropriate balance depends on the industrial domain, regulatory constraints, safety requirements, and the acceptable level of operational transparency.

7.3. Deployment feasibility in IIoT

AdaCap-IIoT is suitable for IIoT environments where direct on-chain authorization for every request would be impractical. It keeps frequent verification, enforcement, and risk evaluation at the edge, while the ledger maintains shared trust evidence. This separation supports local, low-latency authorization near the physical process and improves scalability by avoiding full ledger transactions for every access request.

The proposed architecture is particularly suitable for environments with edge gateways, industrial DMZs, local control networks, or platform services that can host verification and monitoring components. In these environments, edge nodes act as local authorization points that synchronize with the ledger for policy, revocation, and audit evidence, while resource-constrained devices avoid heavy blockchain operations.

Deployment feasibility depends on selecting a ledger that meets industrial latency, throughput, governance, and availability requirements. Permissioned or consortium ledgers may be preferable because they offer stronger governance and more predictable performance. The edge layer must also synchronize reliably with policy and revocation state, while zero-knowledge proof operations must be configured according to the computational capabilities of subjects and edge nodes. In many cases, constrained devices may need gateways or proxies to generate proofs or manage capability material.

Operational integration is also critical. AdaCap-IIoT should interoperate with existing identity-management systems, industrial protocols, monitoring platforms, and security operations processes. To avoid the disruption of critical functions, adaptive enforcement should support constrained decisions, such as reduced scope, read-only access, shorter sessions, or human approval, rather than only binary grant-or-deny decisions.

7.4. Limitations

The main limitation of AdaCap-IIoT is that we presented a conceptual reference architecture rather than a fully implemented and benchmarked system. Although it combines mechanisms that have been studied in blockchain-enabled CapBAC, zero-knowledge verification, edge authorization, and information flow control, the performance and scalability of their integration still require validation through prototype implementation and empirical evaluation.

A second limitation concerns computational and communication overhead. Zero-knowledge proofs can reduce information disclosure, but proof generation may introduce overhead for constrained subjects. Edge-side verification mitigates this issue by moving verification away from the ledger, but the architecture still requires careful parameter selection, proof-system optimization, and workload-aware placement of verification nodes. Similarly, information flow monitoring improves post-authorization control, but continuous monitoring can increase storage, computation, and communication costs.

A third limitation concerns trust placement. AdaCap-IIoT reduces reliance on centralized authorization servers, but it introduces strong security expectations for edge nodes. If an edge verifier or enforcement point is compromised, an attacker may attempt to approve invalid requests, hide risk signals, delay revocation, or manipulate local enforcement decisions. Therefore, edge nodes require hardening, remote attestation, redundancy, secure logging, and periodic consistency checks against ledger-anchored evidence.

Another limitation concerns policy correctness and risk evaluation. AdaCap-IIoT adapts capability scope and revocation decisions based on risk indicators, but these decisions depend on accurate policies, thresholds, and information flow metrics. Misconfiguration may either block legitimate operations or fail to restrict malicious behavior, so adaptive decisions must remain auditable and aligned with industrial safety requirements.

Finally, AdaCap-IIoT does not fully resolve interoperability challenges. IIoT environments often include legacy devices, proprietary protocols, vendor-specific gateways, and multiple administrative domains. Deploying capability-based authorization in such settings requires careful mapping of identities, device roles, permissions, and capability semantics.

7.5. Research directions

Future work should first implement AdaCap-IIoT as a proof-of-concept prototype and evaluate its performance under realistic IIoT workloads. Such evaluation should measure proof generation time, edge-side verification latency, ledger synchronization overhead, revocation propagation delay, throughput under concurrent requests, and the computational cost of information flow monitoring. These measurements are necessary to determine which parts of the architecture can run on constrained devices and which should be delegated to gateways or edge servers.

A second research direction concerns adaptive risk evaluation. We should define and validate risk-scoring models that combine capability use, device behavior, request context, delegation patterns, failed attempts, and information flow indicators. These models should support incremental updates so that the system can respond quickly without re-computing the entire dependency graph after every event. They should also provide auditable decisions, allowing operators to understand why a capability was restricted, suspended, or revoked.

Finally, future work should examine cross-domain deployment scenarios. Industrial ecosystems often involve manufacturers, operators, maintenance providers, cloud platforms, and external auditors. AdaCap-IIoT should therefore be evaluated in multi-domain environments where capability issuance, delegation, attenuation, revocation, and audit responsibilities are distributed across organizations with different trust assumptions and governance requirements.

8. Conclusion

Blockchain-enabled CapBAC is a promising approach for securing distributed IIoT environments, especially where scalability, low latency, delegation, auditability, and cross-domain operation are required. However, our comparative analysis shows that existing models address these requirements partially. Most approaches support selected lifecycle functions, such as issuance, verification, delegation, or revocation, but remain access-centric and rarely combine lifecycle management with runtime adaptivity, privacy-preserving verification, robust revocation, controlled delegation, and post-authorization information flow monitoring.

To address these limitations, we proposed AdaCap-IIoT, a reference architecture for adaptive blockchain-enabled CapBAC in IIoT environments. AdaCap-IIoT separates ledger-based trust anchoring from edge-side verification, risk evaluation, and local enforcement. This design reduces unnecessary on-chain interaction, limits exposure of sensitive operational metadata, and supports low-latency access control decisions near the industrial process. A key contribution of AdaCap-IIoT is its lifecycle-driven authorization workflow. Rather than handling capabilities as static tokens checked only at access time, AdaCap-IIoT manages them as dynamic authorization objects whose scope, duration, verification requirements, delegation rights, revocation priority, audit intensity, and renewal can adapt to trust, context, operational risk, and observed information flows.

The proposed architecture highlights the need to balance auditability and privacy in blockchain-enabled IIoT access control. AdaCap-IIoT keeps detailed capability contents and operational evidence off-chain, while using commitments, policy references, revocation evidence, and zero-knowledge verification to provide accountability without exposing critical identities, access patterns, or operational metadata (Lykou et al., 2018).

Future work should focus on implementing AdaCap-IIoT and evaluating it under realistic IIoT workloads. The evaluation should examine proof generation and verification latency, revocation propagation, ledger synchronization, edge-side throughput, monitoring overhead, and resilience against compromised or unavailable edge nodes. Additional research should also explore privacy-preserving audit mechanisms, accumulator-based revocation, explainable risk evaluation, and cross-domain deployment scenarios.

CRedit authorship contribution statement

Argiro Anagnostopoulou: Writing – original draft, Methodology, Investigation, Formal analysis, Conceptualization. **Dimitris Gritzalis:** Writing – review & editing, Supervision, Methodology, Conceptualization. **Ioannis Mavridis:** Writing – review & editing, Validation, Formal analysis.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

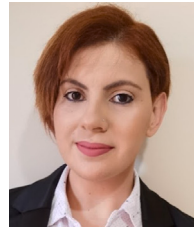
Data availability

No data was used for the research described in the article.

References

- Anagnostopoulou, A., Kehrioti, E., Mavridis, I., Gritzalis, D., 2025. Bolstering IIoT resilience: The synergy of blockchain and CapBAC. In: *Proceedings of the 22nd International Conference on Security and Cryptography*. Vol. 1, pp. 120–131.
- Page, M.J., McKenzie, J.E., Bossuyt, P.M., Boutron, I., Hoffmann, T.C., Mulrow, C.D., Shamseer, L., Tetzlaff, J.M., Akl, E.A., Brennan, S.E., et al., 2021. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *Bmj* 372.
- Ahmed, S.F., Alam, M.S.B., Hoque, M., Lameesa, A., Afrin, S., Farah, T., Kabir, M., Shafiullah, G., Mueen, S., 2023. Industrial internet of things enabled technologies, challenges, and future directions. *Comput. Electr. Eng.* 110, 108847.
- Latif, S., Idrees, Z., e Huma, Z., Ahmad, J., 2021. Blockchain technology for the industrial internet of things: A comprehensive survey on security challenges, architectures, applications, and future research directions. *Trans. Emerg. Telecommun. Technol.* 32 (11), e4337.
- Kumar, R.L., Khan, F., Kadry, S., Rho, S., 2022. A survey on blockchain for industrial internet of things. *Alex. Eng. J.* 61 (8), 6001–6022.
- Wang, Q., Zhu, X., Ni, Y., Gu, L., Zhu, H., 2020. Blockchain for the IoT and industrial IoT: A review. *Internet Things* 10, 100081.
- Hernández-Ramos, J.L., Jara, A.J., Marin, L., Skarmeta, A.F., 2013. Distributed capability-based access control for the internet of things. *J. Internet Serv. Inf. Secur. (JISIS)* 3 (3/4), 1–16.
- Nakamura, S., Enokido, T., Takizawa, M., 2021a. Implementation and evaluation of the information flow control for the internet of things. *Concurr. Comput.: Pract. Exp.* 33 (19), e6311.
- Lesavre, L., Varin, P., Yaga, D., 2020. *Blockchain Networks: Token Design and Management Overview*. Technical Report, National Institute of Standards and Technology.
- Liu, Y., Lu, Q., Chen, S., Qu, Q., O'Connor, H., Choo, K.-K.R., Zhang, H., 2021. Capability-based IoT access control using blockchain. *Digit. Commun. Netw.* 7 (4), 463–469.
- Nakamura, Y., Zhang, Y., Sasabe, M., Kasahara, S., 2019. Capability-based access control for the internet of things: An ethereum blockchain-based scheme. In: *2019 IEEE Global Communications Conference. GLOBECOM, IEEE*, pp. 1–6.
- Le, T., Mutka, M.W., 2018. Capchain: A privacy preserving access control framework based on blockchain for pervasive environments. In: *2018 IEEE International Conference on Smart Computing. SMARTCOMP, IEEE*, pp. 57–64.

- Sun, S., Chen, S., Du, R., Li, W., Qi, D., 2019. Blockchain based fine-grained and scalable access control for iot security and privacy. In: 2019 IEEE Fourth International Conference on Data Science in Cyberspace. DSC, IEEE, pp. 598–603.
- Bouras, M.A., Xia, B., Abuassba, A.O., Ning, H., Lu, Q., 2021. IoT-CCAC: a blockchain-based consortium capability access control approach for IoT. *PeerJ Comput. Sci.* 7, e455.
- Xu, R., Chen, Y., Blasch, E., Chen, G., 2018. Blendcac: A blockchain-enabled decentralized capability-based access control for iots. In: 2018 IEEE International Conference on Internet of Things and IEEE Green Computing and Communications and IEEE Cyber, Physical and Social Computing and IEEE Smart Data. IEEE, pp. 1027–1034.
- Truong, H., Hernández-Ramos, J.L., Martinez, J.A., Bernal Bernabe, J., Li, W., Marin Frutos, A., Skarmeta, A., 2022. [Retracted] enabling decentralized and auditable access control for IoT through blockchain and smart contracts. *Secur. Commun. Netw.* 2022 (1), 1828747.
- Liao, J., Wu, Q., 2023. DTSAC: Smart contract-based access control with delegation and trust management. In: 2023 IEEE 29th International Conference on Parallel and Distributed Systems. ICPADS, IEEE, pp. 639–644.
- Li, C., Li, F., Yin, L., Luo, T., Wang, B., 2021. A blockchain-based IoT cross-domain delegation access control method. *Secur. Commun. Netw.* 2021 (1), 3091104.
- Pinjala, S.K., Sivalingam, K.M., 2019. DCACI: A decentralized lightweight capability based access control framework using IOTA for internet of things. In: 2019 IEEE 5th World Forum on Internet of Things. WF-IoT, IEEE, pp. 13–18.
- IOTA Foundation, 2025. IOTA Technical and Tokenomics Whitepaper. Technical Report, IOTA Foundation, URL: https://www.iota.org/pdf/IOTA_Technical_and_Tokenomics_Whitepaper.pdf.
- Pal, S., Jadidi, Z., 2021. Analysis of security issues and countermeasures for the industrial internet of things. *Appl. Sci.* 11 (20), 9393.
- Lashkari, B., Musilek, P., 2021. A comprehensive review of blockchain consensus mechanisms. *IEEE Access* 9, 43620–43652.
- Polat, B., Göçmenoglu, I., 2022. Comparison between consensus algorithms in an IIoT network: Analysis of proof of work, proof of stake and proof of authentication.
- Pal, S., Dorri, A., Jurdak, R., 2022. Blockchain for IoT access control: Recent trends and future research directions. *J. Netw. Comput. Appl.* 203, 103371.
- Nakamura, S., Enokido, T., Takizawa, M., 2021b. Information flow control based on capability token validity for secure IoT: implementation and evaluation. *Internet Things* 15, 100423.
- Groth, J., 2016. On the size of pairing-based non-interactive arguments. In: *Advances in Cryptology – EUROCRYPT 2016*. In: *Lecture Notes in Computer Science*, vol. 9666, Springer, pp. 305–326. http://dx.doi.org/10.1007/978-3-662-49896-5_11.
- Nitulescu, A., 2020. Zk-SNARKs: A gentle introduction. Available online.
- Ramezan, G., Meamari, E., 2024. Zk-IoT: Securing the internet of things with zero-knowledge proofs on blockchain platforms. In: 2024 IEEE International Conference on Blockchain and Cryptocurrency. ICBC, IEEE, pp. 1–7.
- Jiang, W., Lin, Z., Tao, J., 2023. An access control scheme for distributed internet of things based on adaptive trust evaluation and blockchain. *High-Confid. Comput.* 3 (2), 100104. <http://dx.doi.org/10.1016/j.hcc.2023.100104>.
- Molina-Jimenez, C., Sfyrakis, I., Solaiman, E., Ng, I., Wong, M.W., Chun, A., Crowcroft, J., 2018. Implementation of smart contracts using hybrid architectures with on and off-blockchain components. In: 2018 IEEE 8th International Symposium on Cloud and Service Computing (SC2). IEEE, pp. 83–90.
- Anastopoulou, A., Tsinganos, N., Chatzopoulos, J., Mavridis, I., Gritzalis, D., 2026. INFFLOW-RT: A real-time, adaptive methodology for risk-based information flow control in IIoT. *Int. J. Inf. Secur.* 25 (1), 16.
- Lykou, G., Mentzelioti, D., Gritzalis, D., 2018. A new methodology toward effectively assessing data center sustainability. *Comput. Secur.* 76, 327–340.



Dr Anagnostopoulou Argiro holds a Ph.D. in Cybersecurity from the Dept. of Informatics, Athens University of Economics & Business (AUEB). She also holds a B.Sc. in Informatics and an M.Sc. in Information Systems from AUEB, Greece. She is a senior researcher at the INFOSEC Research Group (AUEB), while her current research interests include the cybersecurity of information and industrial control systems, the protection of critical infrastructures, and the enhancement of access control through information-flow control. She has been actively involved in various research projects focusing on cybersecurity and critical infrastructure protection. She has authored and co-authored several research papers in international journals and conferences. Finally, Argiro has served as a reviewer for numerous scientific journals and conferences.



Dr Dimitris Gritzalis is a Professor of Cybersecurity with the Dept. of Informatics, Athens University of Economics & Business (AUEB), Greece, where he also serves as Director for the M.Sc. Programme in Information Systems Security. He holds a B.Sc. (Mathematics, Univ. of Patras, GR), a M.Sc. (Computer Science, City University of New York, US), and a Ph.D. (Information Systems Security, Univ. of the Aegean, GR). He served as Associate Rector for Research (AUEB), President of the Greek Computer Society (GCS), and Associate Data Protection Commissioner of Greece. His current research interests include cybersecurity, critical infrastructure protection, risk assessment, malware, access control, and security education. He is the Academic Editor of *Computers & Security* (Elsevier) and the Scientific Editor of the *International Journal of Critical Infrastructure Protection* (Elsevier).



Ioannis Mavridis received the Diploma degree in computer engineering and informatics from the University of Patras, Greece, and the Ph.D. degree in information systems security from the Aristotle University of Thessaloniki, Greece. He is currently a Professor of information security with the Department of Applied Informatics, University of Macedonia (UoM), Greece. He is also the Director of the Multimedia, Security and Networking Laboratory (MSN Lab). His research interests include AI-based attack detection, cybersecurity education, risk management, access control, cyber threat intelligence, digital forensics, and security economics. He serves as an Area Editor for the *Array* journal (Elsevier).